

Crypto-Agility Assessment

2026, 2027 and beyond

Version 2.0 | Reviewed 29 September 2026

Prepared by Ankit Gupta

Static PDF companion

Use the matching XLSX for editable inventory records, formulas, drop-downs, evidence, owners and status. This PDF is a readable reference and is not an interactive workbook.

How to use this companion

Start with scope and accountable owners. Record the cryptographic dependency, confidentiality or authenticity lifetime, algorithm and implementation evidence. Prioritize exposed, long-lived, high-impact dependencies; confirm supported protocol and product paths; test interoperability, failure modes, rollback and operational impact before deployment.

Final standards, drafts, research selections and local planning targets are different statuses. NIST alignment means the material draws from the listed sources; it does not claim NIST endorsement or completeness of every future recommendation.

Workbook: [secureazcloud-crypto-agility-assessment-template-v2.0.xlsx](#)

Included worksheets

Start Here | Crypto Inventory | Assessment Checklist | Scoring Model | Migration Roadmap | Vendor Questions | Sources | Threat Register

Start Here

Read this section alongside the corresponding worksheet in the editable workbook. Record decisions and evidence there.

2026-2035 and continuing operations. Updated against public NIST sources available on 2026-09-29. All populated assets are examples.

Version: v2.0

Updated: 2026-09-29

Author / Maintainer: Ankit Gupta

Purpose: Use this workbook to create an evidence-backed inventory of cryptographic dependencies and score migration priority for quantum-vulnerable assets.

Public/redacted use: No internal hostnames, customer names, secrets, key material, IP addresses, or proprietary architecture details are required. Use placeholders or evidence links to internal systems when sharing externally.

Recommended sequence: 1) Replace the five example assets. 2) Complete identity, scoring, dependency and evidence fields. 3) Review threats and assessment items. 4) Apply the calendar roadmap and retain approval/test evidence.

Scoring model: P1/P2/P3, weights and 90/180-day review targets are SecureAzCloud planning heuristics, not NIST requirements. Edit numeric weights and thresholds in Scoring_Model. Unknowns need investigation; incomplete records are not scored.

Evidence standard: Completion requires owner, test/validation evidence, production approval, rollback/restore evidence and test date. Example records cannot be marked complete. Supplier support alone does not prove deployed protection.

Caution: This is a planning aid, not a certification. Deploy PQC changes only after architecture review, standards/protocol support, vendor support, testing, and rollback planning.

2026 and future guidance: FIPS 203/204/205 are final. SP 800-227 is final. CSWP 39 Update 1 is the final agility reference. IR 8547 is still an initial public draft; its dates are planning signals, not a blanket mandate.

Algorithm maturity: ML-KEM establishes shared secrets; ML-DSA and SLH-DSA sign. Algorithm standards do not prove protocol/product support or FIPS 140 validation. Track FN-DSA and HQC as pending, not approved deployed standards.

Roadmap convention: 2026, 2027, 2028-2030, 2031-2035 and post-2035 actions are local recommendations. Set earlier targets for long-lived secrets, criticality, replacement lead time and applicable obligations.

Refreshing evidence: Recheck Sources and NIST errata at least quarterly and after a major standards, vulnerability, vendor or architecture change. Record owner, evidence and review date.

Template capacity: 50 inventory records (rows 2-51). Copy formulas, validations and formatting when extending. Also extend bounded duplicate checks before adding row 52. CSV is a static inventory export and does not retain workbook formulas or other tabs.

Threat mapping: Threat_Register uses scenario IDs. Record applicable IDs in Crypto_Inventory and link supporting controls/evidence. Threats are scenarios to assess, not claims that an incident has occurred.

Validation boundary: CAVP algorithm validation, CMVP module validation and deployed protocol correctness are separate. Record certificate status, module/version/environment, approved mode and covered PQC services. Historical status is not revoked.

Draft watch: Monitor SP 800-57 Rev. 6, SP 800-131A Rev. 3, SP 800-133 Rev. 3, SP 800-230 and SP 800-82 Rev. 4 as drafts. Future unpublished recommendations cannot be certified in advance.

Crypto Inventory

The editable workbook contains the full data-entry template. The field structure below identifies information to collect. Example records are illustrative and are not a validated production inventory.

Fields in the editable worksheet

01. Asset ID
02. System/Service
03. Environment
04. Business Function
05. Owner/Team
06. Data Classification
07. Long-Lived Data?
08. Confidentiality Horizon
09. External Exposure
10. Business Criticality
11. Cryptographic Function
12. Protocol/Use Case
13. Algorithm / Key Type
14. Key Size / Curve / Parameter
15. Certificate/Key Store
16. Vendor/Product
17. Library/Provider
18. Hardware/Firmware Dependency?
19. PQC Support Status
20. Crypto-Agility Level
21. Data Life Score
22. Exposure Score
23. Criticality Score
24. Quantum Vulnerability Score
25. Supplier Readiness Score
26. Migration Effort Score
27. Calculated Risk Score
28. Priority
29. Recommended Action
30. Target Quarter
31. Evidence Link
32. Notes
33. Record Type
34. Algorithm Family
35. Protocol/Profile Maturity
36. Component Version
37. Upstream Dependency IDs
38. Relying Parties / Downstream IDs
39. Discovery Method
40. Discovery Date
41. Protection Lifetime (years)
42. Migration Lead Time (years)
43. Target Algorithm / Profile
44. Validation / Test Evidence
45. Migration Status
46. Production Approval / Reviewer
47. Rollback / Restore Evidence
48. Last Test Date

- 49. Vendor Support End
- 50. Exception Expiry
- 51. Threat IDs
- 52. Source References
- 53. Record / Scoring Gate
- 54. Completion Gate

Illustrative records - selected fields

01 Example customer portal TLS

Asset ID: A-001

Business Function: Customer web access

Cryptographic Function: Key establishment

Protocol/Use Case: TLS 1.2/1.3

Algorithm / Key Type: ECDHE_RSA

Target Quarter: 2026-Q4

Notes: Example only; replace with organization evidence.

Algorithm Family: Classical public-key

Protocol/Profile Maturity: Profile review required

Target Algorithm / Profile: ML-KEM in supported protocol; authentication separately

02 Example code-signing pipeline

Asset ID: A-002

Business Function: Software release integrity

Cryptographic Function: Digital signature

Protocol/Use Case: Artifact/code signing

Algorithm / Key Type: RSA

Target Quarter: 2027-Q1

Notes: Identify PQC signature roadmap and test artifact verification impact.

Algorithm Family: Classical public-key

Protocol/Profile Maturity: Profile review required

Target Algorithm / Profile: ML-DSA or SLH-DSA with supported signing profile

Assessment Checklist

Use each item with evidence, an accountable owner, a target date, and the editable workbook status fields. An unchecked control is not satisfied by this reference document.

01 Define PQC migration scope and executive sponsor.

Domain: Governance

Expected Evidence: Approved charter, roles, decision rights.

Priority: P1

Source References: CSWP39; CSF2

02 Define crypto-agility policy: approved libraries, protocols, algorithms, and exception process.

Domain: Governance

Expected Evidence: Policy or standard with approval workflow.

Priority: P1

Source References: CSWP39; CSF2

03 Inventory public-key cryptography across TLS, SSH, VPN, PKI, code signing, token signing, S/MIME, API gateways, and device auth.

Domain: Inventory

Expected Evidence: Inventory export and evidence links.

Priority: P1

Source References: CSWP39; CSF2

04 Flag long-lived data and harvest-now-decrypt-later exposure.

Domain: Inventory

Expected Evidence: Data classification, retention, and confidentiality horizon.

Priority: P1

Source References: CSWP39; CSF2

05 Identify crypto logic embedded in applications, firmware, appliances, and third-party services.

Domain: Architecture

Expected Evidence: Dependency map and architecture notes.

Priority: P1

Source References: CSWP39; CSF2

06 Document abstraction points for crypto providers and protocol stacks.

Domain: Architecture

Expected Evidence: Architecture diagram or design record.

Priority: P2

Source References: CSWP39; CSF2

07 Inventory CAs, certificate profiles, key algorithms, validity periods, and relying-party constraints.

Domain: PKI

Expected Evidence: CA export, CT logs, certificate scan.

Priority: P1

Source References: CSWP39; CSF2

08 Assess workload identity, token signing, service principals, federation, and managed certificate dependencies.

Domain: Cloud/IAM

Expected Evidence: IAM inventory and certificate map.

Priority: P1

Source References: CSWP39; CSF2

09 Request vendor PQC roadmap, standards support, interoperability test evidence, and support-window commitments.

Domain: Supplier

Expected Evidence: Vendor response and procurement language.

Priority: P1

Source References: CSWP39; CSF2

10 Build non-production test plan for TLS handshake size, certificate chain size, performance, logging, and rollback.

Domain: Testing

Expected Evidence: Test plan and acceptance criteria.

Priority: P1

Source References: CSWP39; CSF2

11 Update change windows, rollback procedures, incident response, monitoring, and exception register.

Domain: Operations

Expected Evidence: Runbook and change record.

Priority: P2

Source References: CSWP39; CSF2

12 Train application, cloud, IAM, PKI, OT, and procurement teams on PQC transition roles.

Domain: Training

Expected Evidence: Training record and communications.

Priority: P2

Source References: CSWP39; CSF2

13 Separate final standards, draft guidance and local deadlines.

Domain: Governance

Expected Evidence: Approved standards register with review owner.

Priority: P1

Source References: IR8547 draft; CSWP39

14 Record dependency edges, deployed versions and discovery dates.

Domain: Inventory

Expected Evidence: Network, source, configuration and vendor evidence reconciled.

Priority: P1

Source References: SP180038B draft; CSWP39

15 Measure completeness against an independently defined asset population.

Domain: Inventory

Expected Evidence: CMDB/cloud/identity scope reconciliation, unknowns and exclusions.

Priority: P1

Source References: CSWP39; CSF2

16 Record confidentiality lifetime, signature verification lifetime and migration lead time.

Domain: Risk

Expected Evidence: Data-owner retention and long-lived firmware/archive requirements.

Priority: P1

Source References: IR8547 draft; CSWP39

17 Use ML-KEM for shared-secret establishment and ML-DSA/SLH-DSA for signatures.

Domain: Algorithms

Expected Evidence: Selected parameters and current FIPS errata recorded.

Priority: P1

Source References: FIPS203; FIPS204; FIPS205

18 Review KEM key generation, encapsulation/decapsulation, randomness, KDF and protocol authentication.

Domain: KEM design

Expected Evidence: SP 800-227 design review and implementation evidence.

Priority: P1

Source References: SP800227

19 Check side-channel/fault handling, decapsulation failure behavior, key handling and secret zeroization.

Domain: Implementation

Expected Evidence: Supplier assurance, test results and applicable module validation.

Priority: P1

Source References: SP800227; FIPS203

20 Approve protocol profile and both peer implementations before deployment.

Domain: Protocol

Expected Evidence: Profile maturity, interoperability matrix and negotiated algorithm evidence.

Priority: P1

Source References: SP180038C draft; CSWP39

21 Prevent silent fallback and exercise downgrade/algorithm-confusion handling.

Domain: Protocol

Expected Evidence: Negative tests and negotiated-suite alerts.

Priority: P1

Source References: CSWP39; SP800227

22 Distinguish algorithm standard, algorithm testing and module validation.

Domain: Validation

Expected Evidence: CAVP/ACVP evidence and CMVP certificate, version and operating environment where required.

Priority: P1

Source References: CMVP; FIPS203

23 Test packet fragmentation, MTU, CPU, memory, load and denial-of-service limits.

Domain: Testing

Expected Evidence: Baseline-versus-PQC measurements and documented acceptance limits.

Priority: P1

Source References: SP180038C draft; CSWP39

24 Test enrollment, chain validation, revocation, trust-store changes and legacy verifiers.

Domain: PKI/signatures

Expected Evidence: CA/RA and relying-party test matrix, archived signature handling.

Priority: P1

Source References: FIPS204; FIPS205; CSWP39

25 Test backup restore, rewrapping, key recovery and rollback without uncontrolled downgrade.

Domain: Recovery

Expected Evidence: Dated recovery exercise and owner-approved rollback thresholds.

Priority: P1

Source References: SP80057; CSWP39

26 Track signed release plans, support end dates, algorithm retirement and replacement lead time.

Domain: Supplier

Expected Evidence: Contract or release evidence tied to actual component version.

Priority: P1

Source References: SP800161; CSWP39

27 Detect crypto drift, newly introduced dependencies, expiring exceptions and changed vendor status.

Domain: Operations

Expected Evidence: Scheduled inventory refresh, release gate and alert/runbook evidence.

Priority: P2

Source References: CSWP39; CSF2

28 Retire vulnerable production use and block reintroduction after migration.

Domain: Migration

Expected Evidence: Configuration inventory, negative tests and exception disposition.

Priority: P1

Source References: IR8547 draft; CSWP39

29 Track FN-DSA, HQC and additional signature work without treating pending standards as final.

Domain: Standards watch

Expected Evidence: Quarterly standards review with as-of date.

Priority: P2

Source References: NIST status

30 Review 2027 and later roadmap annually and after standards or threat changes.

Domain: Governance

Expected Evidence: Risk-approved budget, milestones and updated source-status register.

Priority: P2

Source References: CSWP39; CSF2

31 Assess all Threat_Register scenarios relevant to each asset.

Domain: Threat review

Expected Evidence: Threat IDs, control evidence and residual risk decisions.

Priority: P1

Source References: CSWP39; IR8547 draft

32 Keep approved algorithms and profiles small and policy-controlled.

Domain: Architecture

Expected Evidence: Versioned allowlist, disabled obsolete algorithms and change approval.

Priority: P1

Source References: CSWP39

33 Version cryptographic message and storage formats so algorithms and parameters can change safely.

Domain: Architecture

Expected Evidence: Schema/version negotiation and backward-compatibility tests.

Priority: P2

Source References: CSWP39

34 Exercise emergency algorithm or provider replacement after compromise or cryptanalytic change.

Domain: Response

Expected Evidence: Measured transition time, communication, fallback boundaries and recovery drill.

Priority: P1

Source References: CSWP39

35 Monitor 2026 key-generation, limited-use signature and lifecycle drafts separately from final baselines.

Domain: Standards watch

Expected Evidence: SP 800-133r3, SP 800-230, SP 800-57r6 and SP 800-131Ar3 status review.

Priority: P2

Source References: Draft watch

36 Assess signed tokens and all assertion validators before algorithm migration.

Domain: Identity

Expected Evidence: Issuer/JWKS/trust distribution, rotation, cache and size-limit tests.

Priority: P1

Source References: IR8587; SP800228

37 Recheck module certificate status after the September 2026 active-list transition.

Domain: Validation

Expected Evidence: CMVP certificate status/date, module/version/environment, approved mode and PQC services. Historical is not revoked.

Priority: P1

Source References: CMVP; CAVP

Scoring Model

Scoring is a local prioritization aid. It is not a NIST scoring formula, product certification, or proof that a system is quantum safe.

Local risk-priority heuristic, not a NIST scoring scheme or compliance result. Higher supplier and effort scores mean a larger migration gap.

Version: v2.0

Updated: 2026-09-29

Author / Maintainer: Ankit Gupta

Factor: Weight | High Score Means | Example evidence

Data Life Score: 0.25 | Long-lived or sensitive data could remain valuable after future quantum capability. | Retention schedule, data classification, legal/regulatory horizon.

External Exposure Score: 0.15 | Asset is internet-facing or reachable by partners/suppliers. | Attack surface scan, network zone, access path.

Criticality Score: 0.2 | Asset supports critical business, safety, regulatory, or customer trust functions. | BIA, critical service mapping, RTO/RPO.

Quantum Vulnerability Score: 0.25 | Classical public-key 5; unknown 4; hybrid 3; symmetric/hash 2; standardized PQC 1. Classify complete use case, not algorithm substring. | Certificate scan, library report, protocol scan.

Supplier Readiness Score: 0.1 | Vendor roadmap is unknown, unsupported, or lacks tested PQC migration path. | Vendor response, product roadmap, support contract.

Migration Effort Score: 0.05 | Crypto is embedded, firmware-bound, or requires significant refactoring. | Architecture record, firmware inventory, change impact analysis.

Total weight: Must equal 100%; blank weights are incomplete. Zero is a valid approved weight.

Weight validity: Each weight is 0-100%; six numeric weights are required.

Priority thresholds: Local thresholds; P1 must exceed P2.

P1 minimum: 80 | Risk score at or above this cutoff.

P2 minimum: 55 | Risk score at or above this cutoff and below P1.

Score range: 20-100 | Weighted 1-5 inputs scaled by 20. Higher means earlier migration review.

Unknown inputs: Investigate | Unknowns use conservative local values. They are not evidence of safety.

Missing inputs: Needs data | Blank source fields are not assigned default scores. Duplicate IDs block scoring.

Algorithm caveat: Whole use case | A PQ KEM with classical authentication is still partly quantum-vulnerable. Hybrid receives a provisional score until its profile and endpoints are verified.

Protection lifetime: Confidentiality and integrity | Inventory lifetime covers both confidentiality retention and signature/firmware verification lifetime. Consider migration lead time without predicting quantum arrival.

Scope caveat: Risk review required | Priority does not imply production readiness or mandatory NIST deadlines. Assess key management, implementation, protocol and dependency risks separately.

Migration Roadmap

Read this section alongside the corresponding worksheet in the editable workbook. Record decisions and evidence there.

01 Create a complete cryptographic dependency baseline.

Phase: 1. Discover

Entry Criteria: Defined scope and asset owners.

Key Activities: Scan certificates, code repos, PKI, cloud, IAM, TLS, VPN, OT, vendors.

Exit Criteria: Inventory populated and evidence links captured.

Evidence Output: Crypto inventory and discovery report.

02 Convert inventory into P1/P2/P3 migration backlog.

Phase: 2. Prioritize

Entry Criteria: Inventory has risk-scoring fields.

Key Activities: Score long-lived data, exposure, criticality, quantum vulnerability, supplier readiness, and effort.

Exit Criteria: Risk-score review completed.

Evidence Output: Priority backlog and exception register.

03 Define migration target-state and crypto-agility architecture.

Phase: 3. Design

Entry Criteria: Priority backlog approved.

Key Activities: Select supported standards, protocol paths, libraries, certificate profiles, and rollback strategy.

Exit Criteria: Target-state design approved.

Evidence Output: Architecture decision record and supplier roadmap.

04 Validate in non-production with measurable acceptance criteria.

Phase: 4. Pilot

Entry Criteria: Design and test environment ready.

Key Activities: Test interoperability, performance, handshake/certificate size, observability, failure, and rollback.

Exit Criteria: Pilot acceptance criteria passed; unresolved risks reviewed before production authorization. Risk acceptance does not mark tests passed.

Evidence Output: Pilot report and change plan.

05 Embed crypto-agility into operations and procurement.

Phase: 5. Operationalize

Entry Criteria: Pilot evidence reviewed.

Key Activities: Update policies, procurement language, monitoring, runbooks, training, and periodic inventory process.

Exit Criteria: Recurring governance cycle active.

Evidence Output: Runbook, dashboard, release notes, training evidence.

Calendar plan - local recommended actions

06 Establish baseline and govern first pilots.

Calendar plan: 2026

Entry / priority basis: Long-lived secrets and critical assets first.

Key actions: Assign sponsor/owners; reconcile discovery; request supplier versions; test standardized algorithms in supported profiles.

Evidence required: Versioned inventory, risk backlog and pilot acceptance plan.

Status / review: Local target. Recheck current NIST status and applicable obligations.

07 Execute prioritized controlled deployments.

Calendar plan: 2027

Entry / priority basis: Approved profiles, supported products, test capacity.

Key actions: Address high HNDL exposure; validate authentication separately; migrate PKI/signing pilots; expand vendor commitments.

Evidence required: Measured interoperability/performance results, approval and rollback tests.

Status / review: Local target. Monitor procurement and replacement lead times.

08 Scale migration and eliminate weaker legacy configurations.

Calendar plan: 2028-2030

Entry / priority basis: Validated deployment waves and refreshed risk priorities.

Key actions: Retire vulnerable public-key uses by risk. IR 8547 proposes deprecation after 2030 for 112-bit RSA/ECDSA/DH/MQV uses.

Evidence required: Production discovery, negative fallback tests, exception owners and expiry.

Status / review: Draft ≥ 128 -bit rows have no 2030 deprecation entry. 2030 is not a universal production ban.

09 Close remaining quantum-vulnerable dependencies.

Calendar plan: 2031-2035

Entry / priority basis: Applicable final guidance and obligations reconfirmed.

Key actions: Resolve long-lived systems, signing/verification chains, suppliers and approved exceptions. Do not defer high-risk cases until 2035.

Evidence required: Retirement records, live crypto telemetry, archival verification and recovery tests.

Status / review: IR 8547 draft plans disallowance after 2035 for quantum-vulnerable public-key schemes.

10 Maintain agility and prevent reintroduction.

Calendar plan: Post-2035

Entry / priority basis: Migrated estate with continuing assurance ownership.

Key actions: Continuously discover; rotate/retire algorithms as evidence changes; refresh supported libraries, protocols and recovery plans.

Evidence required: Recurring crypto inventory, standards/errata watch and incident exercises.

Status / review: Continuing local operating model; future standards are not pre-certified.

11 These are SecureAzCloud milestones.

Calendar plan: Planning note

Entry / priority basis: NIST does not prescribe this workbook schedule.

Key actions: IR 8547 distinguishes algorithms, parameters and uses. Apply the final effective policy for your system.

Evidence required: Sources tab identifies final/draft status and check date.

Status / review: Review at least quarterly and on material change.

12 Assign individual migration actions to asset IDs.

Calendar plan: Record work

Entry / priority basis: Use Crypto_Inventory target quarter and owner.

Key actions: Record dependency order, maintenance window, test evidence, approval and rollback in your change system.

Evidence required: Link the change/evidence record in Crypto_Inventory.

Status / review: Completion is calculated from actual evidence fields.

Vendor Questions

Read this section alongside the corresponding worksheet in the editable workbook. Record decisions and evidence there.

01 Does the service support NIST-standardized PQC algorithms or documented hybrid transition paths for managed TLS, KMS, HSM, service endpoints, and APIs?

Category: Cloud services

Required Evidence: Product roadmap, version details, test results, support timelines.

Priority: P1

Source References: CSWP39; SP800161

02 What PQC or hybrid TLS support is available for browsers, web servers, proxies, gateways, and load balancers?

Category: Web software

Required Evidence: Supported protocol versions, configuration guide, interoperability notes.

Priority: P1

Source References: CSWP39; SP800161

03 How are long-lived encrypted data, full disk encryption, and key wrapping dependencies affected by PQC transition planning?

Category: Endpoint/data-at-rest

Required Evidence: Algorithm inventory, KMS/HSM roadmap, lifecycle documentation.

Priority: P2

Source References: CSWP39; SP800161

04 What certificate profiles, chain-size limits, key algorithms, and relying-party constraints apply to ML-DSA/SLH-DSA or hybrid trials?

Category: PKI/certificates

Required Evidence: CA roadmap, certificate profile, interoperability test result.

Priority: P1

Source References: CSWP39; SP800161

05 How will token signing, federation metadata, workload identity, and service credential verification migrate?

Category: Identity/IAM

Required Evidence: IdP roadmap, signing algorithm support, relying-party guidance.

Priority: P1

Source References: CSWP39; SP800161

06 What firmware, gateway, protocol, and maintenance-window constraints affect PQC or hybrid deployment?

Category: OT/ICS

Required Evidence: Support lifecycle, test procedure, rollback guidance.

Priority: P1

Source References: CSWP39; SP800161

07 Can supplier provide SBOM/CBOM or equivalent cryptographic disclosure with algorithm, key size, protocol, library, and dependency details?

Category: Supply chain

Required Evidence: CBOM/SBOM, architecture evidence, cryptographic bill of materials.

Priority: P1

Source References: CSWP39; SP800161

08 Which exact FIPS algorithms, parameter sets and current errata apply to the offered version?

Category: Standards status

Required Evidence: Algorithm identifiers, versioned documentation and errata disposition.

Priority: P1

Source References: FIPS203; FIPS204; FIPS205

09 Is algorithm testing or FIPS 140 module validation claimed? What is the exact certificate and operating environment?

Category: Validation

Required Evidence: Certificate/status/check date, module version/OE, approved mode and covered PQC services. Roadmap is not validation.

Priority: P1

Source References: CMVP; CAVP

10 Which final or experimental protocol profile is used, and do both endpoints interoperate?

Category: Protocol maturity

Required Evidence: Profile identifier/status and tested peer/version matrix.

Priority: P1

Source References: SP180038C draft; CSWP39

11 What combiner, negotiation, authentication and fallback rules apply? Can downgrade be detected and prevented?

Category: Hybrid and fallback

Required Evidence: Design review, configuration and negative-test evidence.

Priority: P1

Source References: SP800227; CSWP39

12 How are randomness, key lifecycle, decapsulation errors and side-channel/fault protections handled?

Category: KEM assurance

Required Evidence: Implementation assurance and SP 800-227 control evidence.

Priority: P1

Source References: SP800227

13 What are latency, throughput, CPU/memory, packet/chain sizes and denial-of-service limits?

Category: Performance

Required Evidence: Reproducible baseline and PQC load-test results.

Priority: P1

Source References: SP180038C draft

14 What are signed commitments for release, support end, algorithm retirement and replacement assistance?

Category: Lifecycle

Required Evidence: Contract/release commitments and upgrade path.

Priority: P1

Source References: SP800161; CSWP39

15 Can backup restore, key recovery, rewrapping and rollback retain authentication and approved protection?

Category: Recovery

Required Evidence: Restore exercise and documented rollback boundaries.

Priority: P1

Source References: SP80057; CSWP39

16 Can the service export negotiated suites, unsupported-peer failures and cryptographic inventory deltas?

Category: Observability

Required Evidence: Sample logs, inventory API, alert integration and retention.

Priority: P2

Source References: CSWP39

17 Can another algorithm or parameter set be introduced without full application replacement?

Category: Future agility

Required Evidence: Provider abstraction, update process, kill switch and agility exercise.

Priority: P2

Source References: CSWP39

18 How are HQC and FN-DSA monitored, and how are experimental features isolated from production claims?

Category: Pending standards

Required Evidence: Status register and policy separating final standards from experiments.

Priority: P2

Source References: NIST status

Sources

Official sources, publication status, and applicability recorded in the workbook. Recheck draft status, errata, and implementation guidance before a production decision.

Author / Maintainer: Ankit Gupta

01 NIST FIPS 203 (FIPS203)

Artifact Alignment: ML-KEM shared-secret establishment; not a signature or complete authenticated protocol.

Public URL: <https://csrc.nist.gov/pubs/fips/203/final>

Publication Status: Final; consult current errata

Publication / Update Date: 2024-08-13

Checked On: 2026-09-29

02 NIST FIPS 204 (FIPS204)

Artifact Alignment: ML-DSA signatures and verifier/PKI migration.

Public URL: <https://csrc.nist.gov/pubs/fips/204/final>

Publication Status: Final; consult current errata

Publication / Update Date: 2024-08-13

Checked On: 2026-09-29

03 NIST FIPS 205 (FIPS205)

Artifact Alignment: SLH-DSA signatures; assess size/performance tradeoffs.

Public URL: <https://csrc.nist.gov/pubs/fips/205/final>

Publication Status: Final; consult current errata

Publication / Update Date: 2024-08-13

Checked On: 2026-09-29

04 NCCoE Migration to PQC

Artifact Alignment: Cryptographic discovery and interoperability project context.

Public URL: <https://www.nccoe.nist.gov/applied-cryptography/migration-to-pqc>

Publication Status: Project page

Publication / Update Date: Living project page

Checked On: 2026-09-29

05 NIST CSWP 39 Update 1 (CSWP39)

Artifact Alignment: Final crypto-agility strategy, governance, abstraction, interoperability and lifecycle.

Public URL: <https://csrc.nist.gov/pubs/cswp/39/upd1/considerations-for-achieving-crypto-agility/final>

Publication Status: Final 2025-12-19; Update 1

Publication / Update Date: 2026-06-29

Checked On: 2026-09-29

06 NIST SP 800-227 (SP800227)

Artifact Alignment: KEM use, key handling, implementation and secure protocol integration.

Public URL: <https://csrc.nist.gov/pubs/sp/800/227/final>

Publication Status: Final

Publication / Update Date: 2025-09-18

Checked On: 2026-09-29

07 NIST IR 8547 (IR8547 draft)

Artifact Alignment: Proposes deprecation after 2030 for 112-bit RSA/ECDSA/DH/MQV uses. ≥ 128 -bit rows disallow after 2035 without a 2030 deprecation entry.

Public URL: <https://csrc.nist.gov/pubs/ir/8547/ipd>

Publication Status: Initial Public Draft

Publication / Update Date: 2024-11-12

Checked On: 2026-09-29

08 NIST SP 1800-38B (SP180038B draft)

Artifact Alignment: Discovery/inventory practices and evidence gaps.

Public URL: [https://csrc.nist.gov/pubs/sp/1800/38/iprd-\(1\)](https://csrc.nist.gov/pubs/sp/1800/38/iprd-(1))

Publication Status: Initial preliminary draft

Publication / Update Date: 2023-12-19

Checked On: 2026-09-29

09 NIST SP 1800-38C (SP180038C draft)

Artifact Alignment: Interoperability and performance testing approach.

Public URL: [https://csrc.nist.gov/pubs/sp/1800/38/iprd-\(1\)](https://csrc.nist.gov/pubs/sp/1800/38/iprd-(1))

Publication Status: Initial preliminary draft

Publication / Update Date: 2023-12-19

Checked On: 2026-09-29

10 NIST SP 800-57 Part 1 Rev. 5 (SP80057)

Artifact Alignment: Key-management lifecycle, cryptoperiod, recovery and protection requirements.

Public URL: <https://csrc.nist.gov/pubs/sp/800/57/pt1/r5/final>

Publication Status: Final

Publication / Update Date: 2020-05-04

Checked On: 2026-09-29

11 NIST SP 800-82 Rev. 3 (SP80082)

Artifact Alignment: Safety, reliability and operational constraints for OT changes.

Public URL: <https://csrc.nist.gov/pubs/sp/800/82/r3/final>

Publication Status: Final

Publication / Update Date: 2023-09-28

Checked On: 2026-09-29

12 NIST SP 800-161 Rev. 1 Update 1 (SP800161)

Artifact Alignment: Supplier lifecycle, procurement and supply-chain risk.

Public URL: <https://csrc.nist.gov/pubs/sp/800/161/r1/upd1/final>

Publication Status: Final Update 1

Publication / Update Date: 2024-11-01

Checked On: 2026-09-29

13 NIST Cybersecurity Framework 2.0 (CSF2)

Artifact Alignment: Govern, Identify, Protect, Detect, Respond and Recover ownership.

Public URL: <https://www.nist.gov/cyberframework>

Publication Status: Final

Publication / Update Date: 2024-02-26

Checked On: 2026-09-29

14 NIST PQC project (NIST status)

Artifact Alignment: Monitor HQC, FN-DSA and additional signature work. Selection is not final standardization.

Public URL: <https://csrc.nist.gov/projects/post-quantum-cryptography>

Publication Status: Living project. HQC/FN-DSA pending

Publication / Update Date: Status checked 2026-09-29

Checked On: 2026-09-29

15 NIST CMVP FAQ (CMVP)

Artifact Alignment: FIPS 140-2 active eligibility ended after 2026-09-21; only 140-3 stays active from 2026-09-22. Historical is not revoked. Check actual certificate/applicability.

Public URL: <https://csrc.nist.gov/Projects/cryptographic-module-validation-program/faqs>

Publication Status: Official FAQ

Publication / Update Date: Checked 2026-09-29

Checked On: 2026-09-29

16 Local methodology

Artifact Alignment: P1/P2/P3, weights, gates, threat scenarios and calendar milestones are SecureAzCloud operational recommendations informed by the sources.

Public URL: <https://github.com/CyberAutomationX/Post-Quantum-Migration-Hub>

Publication Status: Local guidance; no NIST certification

Publication / Update Date: 2026-09-29

Checked On: 2026-09-29

17 NIST CAVP (CAVP)

Artifact Alignment: Algorithm testing/validation is not module validation or proof of protocol/deployment correctness.

Public URL: <https://csrc.nist.gov/projects/cryptographic-algorithm-validation-program>

Publication Status: Official validation program

Publication / Update Date: 2026-09-22

Checked On: 2026-09-29

18 NIST IR 8587 (IR8587)

Artifact Alignment: Signed-token and assertion ecosystems. Section 7.7 PQC migration and verifier interoperability.

Public URL: <https://csrc.nist.gov/pubs/ir/8587/final>

Publication Status: Final

Publication / Update Date: 2026-09-15

Checked On: 2026-09-29

19 NIST SP 800-228 Update 1 (SP800228)

Artifact Alignment: API lifecycle risks and controls; updated risk/control appendices.

Public URL: <https://csrc.nist.gov/pubs/sp/800/228/upd1/final>

Publication Status: Final; original 2025-06-27

Publication / Update Date: 2026-03-13

Checked On: 2026-09-29

20 NIST SP 800-57 Part 1 Rev. 6 (Draft watch)

Artifact Alignment: PQC-aware key management and storage proposals. Rev. 5 remains final.

Public URL: <https://csrc.nist.gov/pubs/sp/800/57/pt1/r6/ipd>

Publication Status: Initial Public Draft

Publication / Update Date: 2025-12-05

Checked On: 2026-09-29

21 NIST SP 800-131A Rev. 2

Artifact Alignment: Current final transition baseline; apply relevant policies and system obligations.

Public URL: <https://csrc.nist.gov/pubs/sp/800/131/a/r2/final>

Publication Status: Final

Publication / Update Date: 2019-03-21

Checked On: 2026-09-29

22 NIST SP 800-131A Rev. 3 (Draft watch)

Artifact Alignment: Proposed algorithm/key-strength transitions. Rev. 2 remains final.

Public URL: <https://csrc.nist.gov/pubs/sp/800/131/a/r3/ipd>

Publication Status: Initial Public Draft

Publication / Update Date: 2024-10-21

Checked On: 2026-09-29

23 NIST SP 800-133 Rev. 3 (Draft watch)

Artifact Alignment: Proposed PQC key generation, seed expansion, KEM and HSM handling.

Public URL: <https://csrc.nist.gov/pubs/sp/800/133/r3/ipd>

Publication Status: Initial Public Draft

Publication / Update Date: 2026-04-17

Checked On: 2026-09-29

24 NIST SP 800-230 (Draft watch)

Artifact Alignment: Proposed limited-use SLH-DSA parameter sets. Strict per-key limits; not final general-purpose options.

Public URL: <https://csrc.nist.gov/pubs/sp/800/230/ipd>

Publication Status: Initial Public Draft

Publication / Update Date: 2026-04-13

Checked On: 2026-09-29

25 NIST SP 800-82 Rev. 4 (Draft watch)

Artifact Alignment: OT/IIoT/cloud, asset management, monitoring and system-management proposals. Rev. 3 remains final.

Public URL: <https://csrc.nist.gov/pubs/sp/800/82/r4/ipd>

Publication Status: Initial Public Draft

Publication / Update Date: 2026-09-21

Checked On: 2026-09-29

26 NIST SP 1339

Artifact Alignment: Backup and restore evidence integrated with OT change and recovery.

Public URL: <https://csrc.nist.gov/pubs/sp/1339/final>

Publication Status: Final

Publication / Update Date: 2026-06-17

Checked On: 2026-09-29

Threat Register

Threat scenarios are planning inputs. Assign an accountable owner, record affected dependencies, and retain the evidence needed to test each treatment.

01 Harvest now, decrypt later

Threat ID: T01

Risk to assess: Captured vulnerable key-establishment traffic or wrapped keys may expose long-lived secrets later.

Local recommended mitigation: Prioritize lifetime and collection exposure; migrate key-establishment/key-wrapping dependencies.

Expected evidence: Inventory lifetime, data path and negotiated-suite evidence.

Source references: IR8547 draft; SP800227

Status: Not Assessed

02 Future signature forgery

Threat ID: T02

Risk to assess: Quantum-vulnerable public keys may permit impersonation or forged software/firmware signatures.

Local recommended mitigation: Migrate signing and all verifiers; retain archive and device lifetime requirements.

Expected evidence: Signer, trust-store and verifier dependency tests.

Source references: FIPS204; FIPS205; IR8547 draft

Status: Not Assessed

03 Downgrade and algorithm confusion

Threat ID: T03

Risk to assess: Fallback, unsupported peers or mixed algorithms can bypass intended protection.

Local recommended mitigation: Use reviewed protocol profiles; bind negotiation and authentication; test reject/fallback behavior.

Expected evidence: Negative tests and negotiated-suite alerts.

Source references: CSWP39; SP800227

Status: Not Assessed

04 Availability and size limits

Threat ID: T04

Risk to assess: Larger keys, signatures and messages may trigger fragmentation, timeouts, load or denial-of-service issues.

Local recommended mitigation: Benchmark real paths and constrained peers; set resource and failover limits.

Expected evidence: MTU, memory, latency and load results with acceptance thresholds.

Source references: SP180038C draft; CSWP39

Status: Not Assessed

05 Unmigrated trust dependency

Threat ID: T05

Risk to assess: A migrated transport can leave classical CA, token, code-signing or verifier paths exposed.

Local recommended mitigation: Map dependencies end to end and assess confidentiality versus authentication separately.

Expected evidence: CA/JWKS/relying-party inventory and verification evidence.

Source references: CSWP39

Status: Not Assessed

06 Unsupported or locked-in product

Threat ID: T06

Risk to assess: Firmware, hardware or supplier lifecycle may prevent timely cryptographic replacement.

Local recommended mitigation: Track support end, release commitments and replacement lead time; govern exceptions.

Expected evidence: Vendor commitments, lifecycle dates and approved replacement plan.

Source references: SP800161; CSWP39

Status: Not Assessed

07 Implementation leakage or failure

Threat ID: T07

Risk to assess: Weak randomness, secret handling, side channels, faults or error oracles can defeat sound algorithms.

Local recommended mitigation: Use maintained implementations; review KEM failure handling and assurance evidence.

Expected evidence: Supplier assurance, test evidence, relevant module/algorithm validation.

Source references: SP800227; FIPS203

Status: Not Assessed

08 Symmetric-key dependency exposure

Threat ID: T08

Risk to assess: Strong data encryption can still rely on vulnerable public-key transport, wrapping or management paths.

Local recommended mitigation: Separate data cipher from key-establishment, authentication and KMS dependencies.

Expected evidence: Key lifecycle and dependency map, recovery and rewrap evidence.

Source references: SP80057; SP800227

Status: Not Assessed

09 Recovery or archival failure

Threat ID: T09

Risk to assess: Restores, retained signatures or old clients may fail after key, trust or algorithm change.

Local recommended mitigation: Exercise restores, key recovery, archival verification and bounded rollback.

Expected evidence: Dated recovery drills and retained verification policy.

Source references: SP80057; CSWP39

Status: Not Assessed

10 Inventory gaps and crypto drift

Threat ID: T10

Risk to assess: Ephemeral workloads, copied libraries or hidden dependencies may reintroduce vulnerable cryptography.

Local recommended mitigation: Combine discovery methods; reconcile scope; integrate refresh into release and procurement processes.

Expected evidence: Coverage denominator, unknowns, version history and release gate results.

Source references: SP180038B draft; CSWP39

Status: Not Assessed

11 Premature standards or assurance claim

Threat ID: T11

Risk to assess: Selected candidates, draft profiles or vendor claims can be mistaken for finalized or validated deployment.

Local recommended mitigation: Maintain final/draft/pending states and version-specific validation evidence.

Expected evidence: Standards review, release matrix and CMVP certificate where required.

Source references: NIST status; CMVP

Status: Not Assessed

12 Unsafe operational change

Threat ID: T12

Risk to assess: Aggressive scanning or untested crypto changes may disrupt safety-critical or constrained systems.

Local recommended mitigation: Use passive discovery where required; coordinate asset owner and maintenance windows; lab-test first.

Expected evidence: Safety review, nonproduction test and approved recovery plan.

Source references: SP80082; CSWP39

Status: Not Assessed